

SIMATS ENGINEERING

ASSESSMENT TOOL 1

COURSE CODE: CSA51

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)

Assessment Tool Weightage: 40%

QUESTIONS: 5

TOTAL MARKS: 50

Annexure A

CONSTRAINT-BASED PROBLEM SOLVING

Code of Conduct:

I Challa Priyadarshini(192311118)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: CH Priyadarshini

Annexure A

CONSTRAINT-BASED PROBLEM SOLVING

1. A financial institution must secure all web transactions using TLS, but legacy systems only support older SSL versions. Design a solution to ensure secure communication.

Constraints:

A. Backward compatibility must be maintained for 20% legacy clients

B. Sensitive data must not be transmitted using SSL

C. System downtime must be minimal during migration

D. Cost of implementation should be optimized

2. An e-commerce platform is considering implementing the SET protocol for payment security but currently uses TLS-based encryption. Analyze and propose a decision.

Constraints:

A. Must support high transaction throughput (10,000 transactions/minute)

B. Compatibility with modern browsers is required

C. Implementation complexity should be minimized

D. Regulatory compliance (PCI-DSS) must be ensured

3. A corporate network is experiencing repeated malware infections that spread rapidly without user interaction. Propose a containment and prevention strategy.

Constraints:

A. The network consists of 500+ interconnected systems

B. Downtime per system should not exceed 10 minutes

C. Detection must occur within 2 minutes of infection

D. Solution must differentiate between virus, worm, and Trojan behavior

4. An organization needs to deploy a firewall architecture to protect its internal network from external threats and insider attacks. Design the solution.

Constraints:

A. Must support both packet filtering and application-level inspection

B. Latency introduced should not exceed 5 ms per request

C. Should handle at least 1 Gbps traffic

D. Must allow secure remote access for employees

5. A large enterprise network generates excessive false positives in its IDS, leading to alert fatigue.

Propose an optimized IDS/IPS solution.

Constraints:

A. Detection accuracy must be at least 95%

B. False positive rate should be reduced below 5%

C. System must process real-time traffic of 2 Gbps

D. Solution should integrate with existing firewall infrastructure

1. Secure TLS Migration for a Financial Institution

Problem Analysis

The financial institution must secure web transactions using modern TLS, but approximately 20% of legacy clients support only older SSL versions. Older SSL protocols should not be used for sensitive financial information because they contain obsolete cryptographic mechanisms and are vulnerable to attacks that modern TLS versions are designed to prevent.

Recommended Solution: Phased TLS Migration with a Compatibility Gateway

The recommended architecture uses a modern TLS termination layer in front of application servers. New clients connect using a current TLS version. Legacy clients are temporarily handled through a separately isolated compatibility gateway, but sensitive transactions are not allowed through the legacy SSL path. The legacy environment is treated as a migration zone rather than a permanent security exception.

Constraint	Solution
20% legacy clients	Identify legacy clients and provide a temporary isolated compatibility service for non-sensitive functions only. Gradually upgrade or replace them.
Sensitive data must not use SSL	Block payment, authentication, account, and personal-data endpoints from legacy SSL. Require modern TLS for these endpoints.
Minimal downtime	Use load-balanced gateways, parallel deployment, canary testing, and phased client migration.
Optimized cost	Reuse existing load balancers/reverse proxies where possible; prioritize replacement of the highest-risk clients first.

Architecture

- Internet → DDoS/WAF layer → TLS gateway/load balancer → application servers → protected databases.
- Modern clients use current TLS directly.
- Legacy compatibility gateway is isolated in a restricted network segment and is permitted only for approved low-risk services.
- Sensitive URLs and APIs enforce modern TLS and reject obsolete protocol versions.
- Central logging records protocol versions, client identities, failures, and attempted insecure connections.

Migration Procedure

First, inventory clients and determine which systems actually require legacy protocols. Second, enable modern TLS at the edge and test all critical applications. Third, move modern clients to the new configuration. Fourth, place remaining legacy clients into a controlled compatibility segment. Fifth,

upgrade or replace those clients in scheduled batches. Finally, disable the legacy compatibility path and verify that no legitimate business process still depends on it.

Security and Availability

A key principle is that backward compatibility should not be allowed to weaken the security of sensitive transactions. A legacy client may receive limited access to a low-risk service during migration, but authentication, payment, account changes, and other sensitive operations must require modern TLS. High availability is maintained through redundant gateways and rolling changes so that one component can be upgraded without taking the entire service offline.

Final Decision

A phased TLS migration with an isolated compatibility layer is the best solution. It maintains limited backward compatibility without permitting sensitive data to travel over obsolete SSL, keeps downtime low through parallel deployment, and controls implementation cost.

2. SET Protocol vs TLS for E-Commerce Payments

Problem Analysis

The e-commerce platform already uses TLS-based protection and is considering the Secure Electronic Transaction (SET) protocol. The decision must consider very high transaction volume, modern-browser compatibility, implementation complexity, and PCI-DSS compliance.

Technical Assessment

SET was designed specifically for card-payment security and uses certificates and cryptographic mechanisms to protect payment transactions. However, it introduced substantial infrastructure and participant-management complexity. Modern web commerce has instead standardized around TLS combined with tokenization, payment gateways, strong authentication, and PCI-DSS controls.

Constraint	SET	TLS-Based Modern Architecture
10,000 transactions/minute	Possible but operationally complex and resource intensive.	Highly scalable with optimized TLS termination and distributed payment services.
Modern browsers	Not a practical modern-browser deployment model.	Native and widely supported.
Low implementation complexity	High complexity due to specialized certificates and payment workflow.	Lower complexity because TLS is already deployed and widely supported.
PCI-DSS	Can contribute to protection but does not by itself establish compliance.	TLS plus tokenization, segmentation, access control, logging and other PCI controls can support compliance.

Recommended Decision: Continue with TLS

The platform should not replace its modern TLS architecture with SET. Instead, it should strengthen the existing TLS-based payment architecture and use a PCI-compliant payment gateway or tokenization service where appropriate. TLS should protect communications between customers, the platform, and payment services, while sensitive cardholder-data exposure should be minimized through tokenization and segmentation.

High-Throughput Design

- Use horizontally scalable application and payment services behind load balancers.
- Use hardware-accelerated or optimized TLS termination where required.
- Use connection reuse and efficient HTTP/TLS configurations.
- Separate payment processing from general web workloads so payment traffic can scale independently.
- Monitor transaction latency, TLS handshake rates, error rates, and capacity.

PCI-DSS Considerations

PCI-DSS compliance is broader than selecting a particular encryption protocol. The organization must protect cardholder data, restrict access, maintain secure configurations, monitor systems, and apply appropriate vulnerability-management and logging controls. TLS is one component of this broader security program.

Final Decision

Continue using TLS rather than adopting SET. This choice best satisfies the requirement for modern-browser compatibility, 10,000 transactions per minute, reduced implementation complexity, and a practical path to PCI-DSS compliance. Payment tokenization and a properly governed PCI-compliant payment service should be considered to reduce the platform's cardholder-data exposure.

3. Malware Containment and Prevention in a 500+ System Network

Problem Analysis

The organization is experiencing malware infections that spread rapidly without user interaction. This behavior is characteristic of automated propagation, particularly worm-like activity, although viruses and Trojans can also participate in broader infection chains. Because the environment contains more than 500 interconnected systems, containment must be automated and fast.

Recommended Strategy: Automated Detection, Segmentation and Response

The solution should combine endpoint detection and response (EDR), network detection and response (NDR), network segmentation, centralized security analytics, automated isolation, vulnerability management, and controlled endpoint restoration. The goal is to detect suspicious behavior within two minutes and isolate affected systems without requiring manual intervention.

Constraint	Solution
500+ interconnected systems	Use centralized EDR/NDR management, identity-aware segmentation, and automated response policies.

Downtime ≤ 10 minutes/system	Automatically quarantine only the affected endpoint and preserve unaffected services; provide rapid recovery procedures.
Detection ≤ 2 minutes	Use continuous endpoint telemetry, network behavioral monitoring, and high-priority automated detections.
Differentiate virus/worm/Trojan	Classify based on propagation, persistence, execution, lateral movement, command-and-control, and user-interaction indicators.

Behavioral Differentiation

Malware Type	Key Behavioral Indicators	Response
Virus	Attaches to files or programs; spreads when infected content is executed or shared.	Quarantine infected files, block execution, scan related files and endpoints.
Worm	Self-propagates across network connections without requiring normal user interaction; often scans for vulnerable systems.	Immediately isolate source/targets, block suspicious scanning and lateral movement, patch vulnerable services.
Trojan	Disguises itself as legitimate software or content; often depends on execution or installation and may establish persistence/C2.	Terminate malicious process, quarantine artifact, block C2, investigate initial execution and persistence.

Containment Workflow

A continuous monitoring system collects endpoint process, file, network, authentication, and system-event telemetry. Detection analytics identify suspicious activity. When confidence exceeds a defined threshold, the orchestration system instructs the endpoint platform or network access control system to quarantine the machine. The endpoint remains connected to management and remediation services but cannot communicate freely with production systems.

- 0–30 seconds: collect and correlate endpoint/network indicators.
- 30–60 seconds: determine severity and likely behavior.
- 60–120 seconds: automatically isolate high-confidence infected systems.
- After isolation: preserve evidence, remove malware, patch the cause, restore the endpoint, and verify clean status.

Prevention Controls

- Network segmentation and least-privilege access reduce lateral movement.
- Rapid vulnerability and patch management removes common worm propagation paths.
- Application allowlisting and endpoint protection reduce unauthorized execution.
- Disable unnecessary services and restrict exposed ports between network segments.

- Use secure backups and tested recovery procedures.

Final Decision

The recommended design is an automated EDR/NDR containment architecture with segmentation and security orchestration. Automated isolation is essential because a 500+ system environment cannot depend on manual response when the required detection window is only two minutes.

4. Firewall Architecture for External and Insider Threats

Problem Analysis

The organization needs a firewall that supports packet filtering and application-level inspection, introduces no more than 5 ms latency per request, handles at least 1 Gbps of traffic, and provides secure remote access.

Recommended Architecture: Layered Next-Generation Firewall Design

A layered firewall architecture should be deployed at the Internet edge, with internal segmentation firewalls protecting critical internal zones. A next-generation firewall (NGFW) can combine stateful packet filtering, application identification and inspection, intrusion prevention, URL/security controls, and VPN functions.

Proposed Network Layout

- Internet → edge router/DDoS protection → redundant NGFW pair → DMZ and internal segmentation zones.
- Public web servers and externally reachable services remain in a DMZ.
- Internal user networks, server networks, database networks, and management networks are separated.
- Remote employees connect through a secure VPN gateway using strong authentication and access policies.
- Critical servers have additional host-based controls so firewall compromise does not expose the entire environment.

Constraint	Design Response
Packet filtering + application inspection	Use stateful firewall rules plus application-aware inspection and IPS capabilities.
Latency ≤ 5 ms/request	Use high-performance appliances, hardware acceleration, optimized policies, local inspection where possible, and capacity headroom.
At least 1 Gbps	Size firewall for more than 1 Gbps under the required security features, not just raw firewall throughput.
Secure remote access	Provide VPN with strong authentication, device posture controls where available, and least-privilege access.

Insider Attack Protection

A perimeter firewall alone cannot adequately protect against insider threats because trusted users may already be inside the network. Internal segmentation is therefore essential. Users should have access only to the systems required for their roles. Database servers should not be directly reachable from ordinary user networks, and administrative interfaces should be restricted to dedicated management networks.

Remote Access

Remote employees should use a centrally managed VPN with strong authentication and role-based access. Remote access should terminate in a controlled security zone and should not automatically provide unrestricted access to the internal network. Access should be logged and monitored.

Performance Strategy

The 5 ms requirement should be validated under realistic traffic conditions with all required inspection features enabled. The firewall should be selected based on measured throughput for the intended rule set, TLS inspection if used, IPS features, VPN encryption, and concurrent sessions. A safety margin should be maintained so performance does not collapse during peak traffic.

Final Decision

A redundant NGFW architecture with DMZ isolation, internal segmentation, application inspection, and integrated or dedicated secure remote access is recommended. This provides stronger protection against both external and insider threats while allowing the performance target to be achieved through appropriate sizing and policy optimization.

5. Optimized IDS/IPS for Reducing False Positives

Problem Analysis

The enterprise generates excessive IDS alerts, causing alert fatigue. The target is at least 95% detection accuracy, less than 5% false positives, real-time processing of 2 Gbps, and integration with the existing firewall.

Recommended Solution: Tuned, Layered IDS/IPS with Behavioral Analytics

The organization should deploy a high-performance IDS/IPS architecture that combines signature detection, behavioral/anomaly analytics, reputation intelligence, asset context, and firewall integration. The main optimization objective is not simply to reduce the number of alerts; it is to reduce low-value alerts while preserving high-confidence detections.

Constraint	Solution
Accuracy $\geq 95\%$	Use validated signatures, threat intelligence, behavioral detection, asset context, and continuous testing against representative traffic.
False positives $< 5\%$	Tune rules, suppress known benign patterns, use thresholds, apply asset/user context, and review recurring alerts.

2 Gbps real-time traffic	Use appropriately sized hardware/software sensors, parallel processing, traffic distribution, and capacity headroom.
Integrate with firewall	Enable bidirectional policy integration where supported: IDS alerts can trigger firewall blocks, while firewall logs provide context.

False-Positive Reduction Process

- Baseline normal traffic for servers, users, applications, and network segments.
- Disable or lower priority for rules that repeatedly trigger on known legitimate behavior.
- Use confidence scores and severity thresholds so analysts focus on actionable alerts.
- Correlate multiple signals before declaring a high-severity incident.
- Apply asset criticality: the same event on a public server and a test machine may have different priorities.
- Continuously review false-positive samples and update detection policies.

Detection Accuracy

Accuracy should be measured using a representative validation dataset and live production feedback. Metrics should include true positives, false positives, false negatives, precision, recall, and detection latency. A single 'accuracy' percentage can be misleading when malicious events are rare, so the organization should track multiple metrics.

2 Gbps Processing Architecture

For 2 Gbps real-time traffic, the sensor must be sized using the throughput of the full inspection workload. Features such as TLS inspection, protocol decoding, IPS signatures, logging, and packet capture can materially reduce effective throughput. Multiple sensors or traffic distribution can be used to avoid a single bottleneck. Redundant sensors should be considered for availability.

Firewall Integration

The IDS/IPS should exchange context with the existing firewall. For example, a high-confidence malicious connection can generate an automated block for a source, destination, application, or indicator. Firewall logs can also help validate whether an alert represents an actual permitted connection. Automated blocking should be restricted to high-confidence events to avoid turning false positives into unnecessary outages.

Final Decision

A tuned high-performance IDS/IPS with behavioral analytics, context-aware correlation, and controlled firewall integration is recommended. The system should be continuously evaluated against the 95% detection and less-than-5% false-positive targets. Alert quality, rather than raw alert volume, should be the primary operational objective.

Conclusion

The five cases demonstrate that cybersecurity decisions must be made against explicit constraints. The TLS problem requires a controlled transition rather than allowing insecure protocols simply for compatibility. The payment-security case favors modern TLS over SET because modern browsers,

scalability, and implementation simplicity are critical. Malware containment requires automation because a large interconnected network cannot depend on slow manual response.

The firewall case requires defense in depth rather than a single perimeter device, especially because insider threats must also be considered. Finally, IDS/IPS optimization requires context-aware detection and continuous tuning so that analysts receive fewer but more meaningful alerts.

Across all five scenarios, the strongest common strategy is phased deployment, segmentation, automation, continuous monitoring, performance testing, and measurable security objectives. These principles allow organizations to satisfy security requirements without ignoring availability, cost, usability, or operational constraints.